

Kịch bản

Xem lại kịch bản dưới đây. Sau đó hoàn thành các hướng dẫn từng bước.

Bạn là một nhà phân tích an ninh mạng làm việc cho một công ty đa phương tiện cung cấp dịch vụ thiết kế web, thiết kế đồ họa và các giải pháp tiếp thị truyền thông xã hội cho các doanh nghiệp nhỏ. Tổ chức của bạn gần đây đã trải qua một cuộc tấn công DoS, xâm nhập mạng nội bộ trong hai giờ cho đến khi nó được giải quyết.

Trong cuộc tấn công, các dịch vụ mạng của tổ chức của bạn đột nhiên ngừng phản hồi do một loạt các gói ICMP đến. Lưu lượng mạng nội bộ bình thường không thể truy cập bất kỳ tài nguyên mạng nào. Nhóm quản lý sự cố đã phản ứng bằng cách chặn các gói ICMP đến, dừng tất cả các dịch vụ mạng không quan trọng ngoại tuyến và khôi phục các dịch vụ mạng quan trọng.

Nhóm an ninh mạng của công ty sau đó đã điều tra sự kiện bảo mật. Họ phát hiện ra rằng một tác nhân độc hại đã gửi một loạt các ping ICMP vào mạng của công ty thông qua một tường lửa chưa được cấu hình. Lỗi hỏng này cho phép kẻ tấn công độc hại áp đảo mạng của công ty thông qua cuộc tấn công từ chối dịch vụ (DoS).

Để giải quyết sự kiện bảo mật này, nhóm bảo mật mạng đã triển khai:

- Quy tắc tường lửa mới để giới hạn tốc độ của các gói ICMP đến
- Xác minh địa chỉ IP nguồn trên tường lửa để kiểm tra địa chỉ IP giả mạo trên các gói ICMP đến
- Phần mềm giám sát mạng để phát hiện các mô hình lưu lượng truy cập bất thường
- Hệ thống IDS/IPS để lọc một số lưu lượng ICMP dựa trên các đặc điểm đáng ngờ

Là một nhà phân tích an ninh mạng, bạn được giao nhiệm vụ sử dụng sự kiện bảo mật này để tạo ra một kế hoạch cải thiện bảo mật mạng của công ty bạn, tuân theo Khung An ninh mạng của Viện Tiêu chuẩn và Công nghệ Quốc gia (NIST) (CSF). Bạn sẽ sử dụng CSF để giúp bạn điều hướng qua các bước khác nhau để phân tích sự kiện an ninh mạng này và tích hợp phân tích của bạn vào một chiến lược bảo mật chung. Chúng tôi đã chia phân tích thành các phần khác nhau trong mẫu bên dưới. Bạn có thể khám phá chúng ở đây:

- **Xác định** rủi ro bảo mật thông qua kiểm toán thường xuyên các mạng nội bộ, hệ thống, thiết bị và đặc quyền truy cập để xác định các lỗ hổng tiềm ẩn trong bảo mật.

- **Bảo vệ** tài sản nội bộ thông qua việc thực hiện các chính sách, thủ tục, đào tạo và các công cụ giúp giảm thiểu các mối đe dọa an ninh mạng.
- Phát hiện các sự cố bảo mật tiềm ẩn và cải thiện khả năng giám sát để tăng tốc độ và hiệu quả **phát hiện**.
- **Phản ứng** để ngăn chặn, vô hiệu hóa và phân tích các sự cố bảo mật; thực hiện các cải tiến cho quy trình bảo mật.

Khôi phục các hệ thống bị ảnh hưởng về hoạt động bình thường và khôi phục dữ liệu hệ thống và/hoặc tài sản đã bị ảnh hưởng bởi sự cố.